

03

BOOK 03 / 08

데이터 흐름과 신뢰 경계

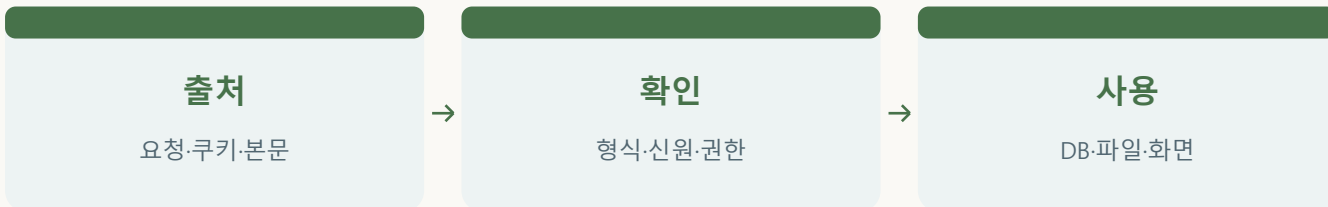
이 값은 어디에서 왔는가?

개념 이해 / 사례 읽기 / 확인 문제 약 15분

비공개 학습 노트 서비스를 따라 배우는 보안의 기본

이 책을 읽는 방법

값의 출처와 검증 근거를 끝까지 따라갑니다.



읽기 순서

학습 목표와 선수 지식	3
시작 상황: 화면에서 막았는데 어떻게 요청했을까?	3
개념 설명	3
흐름 비교	4
개발·검수 시 확인사항	4
핵심 요약	4
확인 문제	5
정답과 해설	6
다음 학습과 출처	6

사례를 먼저 읽고, 개념과 코드의 차이를 확인한 뒤 문제를 풀어 보세요. 정답과 해설은 문제 다음 페이지에서 시작합니다.

공통 사례 / 비공개 학습 노트

민서(사용자 101)의 노트는 10번, 준호(202)의 노트는 20번입니다. 모든 노트는 비공개이며, 로그인한 소유자만 조회·수정할 수 있습니다. 제목은 1~80자의 일반 텍스트입니다.

비밀번호·세션 토큰은 로그에 남기지 않고, 권한을 확인할 수 없으면 본문을 보내지 않습니다. 이 가상 서비스의 예제는 학습용 축약본이며 실제 서비스의 계정·데이터·구현과 무관합니다.

학습 목표와 선수 지식

변수와 함수 인자의 의미를 알고 있다고 가정합니다. 학습 후에는 입력의 출처와 사용 지점을 구분하고, 브라우저에서 제한한 값도 서버에서 검증해야 하는 이유를 설명할 수 있습니다.

시작 상황: 화면에서 막았는데 어떻게 요청했을까?

화면에는 '내 노트 보기' 버튼만 있습니다. 다른 사람의 노트를 선택하는 버튼은 없습니다. 그래도 사용자는 서버에 보내는 노트 번호를 직접 바꿀 수 있습니다. 화면이 제공하는 선택지가 서버에 도달할 수 있는 모든 요청을 뜻하지는 않습니다.

개념 설명

웹 브라우저는 서버에 요청을 보내고 서버는 결과를 응답합니다. HTTP는 이 요청과 응답을 주고받기 위한 규칙입니다. 요청에는 주소, 헤더, 쿠키, 본문 등이 포함될 수 있습니다. 화면 입력칸뿐 아니라 이 값들도 외부 입력입니다.

PSEUDOCODE / 흐름 읽기

```
브라우저: GET /notes/10 요청, 로그인 상태를 나타내는 쿠키 전송
  ↓ 브라우저에서 서버로 들어오는 경계
서버: 세션 확인 → 노트 번호 검사 → 소유자 조건을 포함해 조회
  ↓ 서버가 DB에 질의
DB: 조건에 맞는 노트 반환
  ↓ 저장된 값이 화면 출력에 사용됨
서버: 출력 위치에 맞게 처리 → 브라우저에 응답
```

신뢰 경계는 데이터의 출처나 권한 수준이 달라져 별도의 확인이 필요한 지점입니다. 사용자가 보낸 `user_id=101`과 서버가 인증 처리로 확인한 사용자 번호 101은 숫자가 같아도 근거가 다릅니다. 전자는 주장이고, 후자는 해당 인증 절차를 거쳐 얻은 결과입니다.

또한 'DB에서 읽었으니 신뢰한다'는 판단은 충분하지 않습니다. 그 값이 원래 사용자가 작성한 제목일 수 있기 때문입니다. 저장 위치가 바뀌어도 데이터가 가진 의미와 출처를 잊으면 안 됩니다.

흐름 비교

PSEUDOCODE / 흐름 읽기

문제가 있는 흐름:

요청 본문에 들어 있는 owner_id를 소유자로 믿는다
그 owner_id의 노트를 반환한다

개선한 흐름:

검증된 세션에서 현재 사용자 번호를 얻는다
요청에서는 조회할 노트 번호만 받는다
현재 사용자 번호와 노트 소유자를 서버에서 비교한다

개선 흐름에서도 세션 검증이 올바르다는 전제가 필요합니다. 쿠키에 적힌 사용자 번호를 그대로 읽는 것을 ‘검증된 세션’이라고 부르면 안 됩니다.

개발·검수 시 확인사항

값을 발견하면 세 가지를 표시합니다. **어디에서 왔는가, 어떤 확인을 거쳤는가, 어디에 사용되는가.** URL·파일 경로·DB 질의·HTML처럼 값의 해석 방식이 달라지는 지점은 특히 주의해서 읽습니다.

프론트엔드 검증은 즉각적인 안내에 유용합니다. 서버는 직접 보낸 요청도 받으므로 보안에 필요한 검증을 자체적으로 수행해야 합니다.

핵심 요약

- 화면에서 선택할 수 없다는 사실은 서버 접근 제한이 아닙니다.
- 같은 값도 출처와 검증 근거가 다르면 다르게 취급합니다.
- 저장된 사용자 입력도 사용 위치에 맞는 처리가 필요합니다.

확인 문제

1. HTML 입력칸에 제목 길이를 80자로 제한했습니다. 서버의 길이 검사를 생략해도 될까요?

2. DB에서 읽은 제목을 HTML 화면에 표시합니다. DB에 있다는 이유로 출력 처리를 생략해도 될까요?

정답과 해설

1. 안 됩니다. 브라우저의 입력 제한을 거치지 않고 요청할 수 있습니다.
2. 안 됩니다. 제목은 사용자 입력에서 시작된 값이므로 HTML에 쓰일 때의 처리도 필요합니다.

다음 학습과 출처

다음 단원에서는 서버가 사용자를 확인하고 권한을 판단하는 절차를 구분합니다. 서버 측 입력 검증 원칙은 [OWASP Input Validation Cheat Sheet](#)를 참고했습니다.

나의 한 문장

이 강의에서 배운 내용을 동료에게 설명한다면 어떻게 말할까요?
